



Handout: Spickzettel + Sicherheits-Audit

ABGABE: MITTWOCH, 15. JULI 2026, 18:00 · HUB → LERNEN → MODUL 2 → ABGABEN

Aufwand: 60-90 Minuten + freiwillige Extra-Aufgabe (+30 Minuten). Formate: PDF, Fotos/Screenshots (auch HEIC), Markdown, Text · max. 15 MB pro Datei.

Falls du nur 5 Minuten hast: die ganze Session in einem Absatz

Eine Buchhalterin bekommt Freitagabend eine Mail von «Microsoft» (Absender: **rmicrosoft**, Phishing). Sie tippt ihr Passwort auf einer perfekten Fake-Seite ein. Samstagabend loggt sich der Angreifer ein, liest und kopiert alles, **niemand merkt es**. Sonntag verschlüsselt er jede Datei der Firma (Ransomware). Montag steht auf jedem Bildschirm eine Lösegeldforderung.

MAIL → KLIKK → LOGIN → BEUTE → ERPRESSUNG · DIE KETTE AN EINER STELLE BRECHEN GENÜGT

Dafür gibt es **vier Schutzringe** um die Kundendaten (Identität → Gerät → Netz → Zugriff) plus ein **Fangnetz** für den Ernstfall (Backup). Und die eine Denkfür für den 5.8.: Sicherheit ist Verantwortung in **drei Schichten**: Rechenzentrum (gemietet, zertifiziert) / unsere Software + Betrieb (**wir, voll verantwortlich**) / Büro + Geräte + Microsoft-Konten (vRv bzw. ihr IT-Partner).

Warum diese Aufgabe genau so (und warum ohne Claude)

Am 5.8. sagen wir einem Wirtschaftsprüfer Sätze wie «unsere Geräte sind verschlüsselt, MFA ist überall Pflicht, Zugriffe laufen über persönliche Konten». **Diese Sätze müssen für jeden von uns vier wirklich stimmen**. Genau das prüfst du jetzt: an deinem eigenen Gerät, an deinen eigenen Konten. Danach ist unsere Haben-Liste belegt, nicht behauptet.

Claude kann diese Aufgabe nicht für dich machen, praktisch nicht: Claude sieht weder deine Festplatten-Verschlüsselung noch deine Konto-Einstellungen. **Erlaubt und sinnvoll**: Claude fragen, WIE man etwas prüft («Wie sehe ich, ob FileVault an ist?»). **Nicht der Sinn**: die Antworten ausdenken lassen.

WICHTIG, vor dem Hochladen: Auf Screenshots NIEMALS Passwörter, Recovery-Codes, vollständige Kontonummern oder private Mails zeigen. Vorher schwärzen oder abschneiden. Die Abgaben sind für alle vier sichtbar. Es geht um den NACHWEIS der Einstellung (z.B. «FileVault: aktiviert»), nie um den Inhalt.

Spickzettel: die Begriffe, sortiert wie im Deck

Die Angriffskette

Phishing	Gefälschte Mail angelt nach deinem Passwort; Erkennungszeichen: Druck + Eile, Absender genau lesen, unerwartet
Ransomware	Erpressungs-Software: verschlüsselt alles und verkauft dir deinen eigenen Schlüssel zurück

Ring 1 · Identität (Wer bist du?)

Passwort-Manager	Tresor: überall einzigartige Zufallspasswörter, du merkst dir genau eins; füllt auf Fake-Seiten nichts aus (bricht den Klick)
MFA	Zweiter Schlüssel (Handy-Bestätigung): gestohlenen Passwort allein ist wertlos (bricht den Login); SMS = GELB, App/Passkey = GRÜN
SSO	Ein Firmen-Login (Microsoft-Konto) für alles: Regeln der Firma gelten automatisch, Austritt wirkt überall

Ring 2 · Gerät (dein Laptop)

EDR / EndpointSecurity	Wachhund statt Türsteher mit Fahndungsfotos: beobachtet VERHALTEN, kann das Gerät isolieren (Endpoint = jedes Endgerät)
Geräteverschlüsselung	Gestohlener Laptop = Briefbeschwerer; FileVault (Mac) / BitLocker (Windows); «at rest» = gespeicherte Daten ohne Schlüssel unlesbar
Patch	Flicken: Update, das ein Sicherheitsloch stopft; kritische Lücken bei uns innert 48h

Ring 3 · Netz (Wer darf mit wem reden?)

Firewall	Türsteher fürs Netz: bei unserer Lösung ist genau EINE Tür öffentlich (Port 443 = HTTPS, das Schloss im Browser)
VPN / Always On VPN	(Automatischer) verschlüsselter Tunnel ins Firmennetz; unsere Lösung braucht keinen, sie läuft im Browser
Zero Trust	Türsteher an jeder Tür statt Burggraben: jede App prüft dich einzeln (Identität + Gerätezustand)

Ring 4 · Zugriff und Daten (Wer darf drinnen was?)

RBAC / Least Privilege	Rechte hängen an Rollen, nicht Personen; jede Rolle nur das Minimum (Hauswart sieht nur seine Liegenschaften)
Audit-Log	Das Kassenbuch der Plattform: wer hat wann was gemacht, mitgeschrieben, nicht wegdiskutierbar

Fangnetz + Ernstfall

Backup 3-2-1	3 Kopien, 2 Systeme, 1 extern + unveränderbar; zählt erst mit GETESTETER Wiederherstellung («ein Backup ohne getesteten Restore ist ein Gerücht»)
RPO / RTO	RPO = Blick zurück (wie viel Arbeit ist weg, bei uns max. 24h) · RTO = Blick nach vorn (wie lange steht alles, bei uns Stunden). P wie Punkt, T wie Time
SLA	Vertraglich zugesagte Werte: Reaktionszeiten, Lösungszeiten, Verfügbarkeit
Monitoring + 24h	Automatische Überwachung rund um die Uhr mit Alarm; Vorfälle mit Kundendaten melden wir dem Kunden innert 24h (nDSG); kein Menschen-Pikett, das sagen wir offen

Aufgabe A · Sicherheits-Audit an dir selbst (ca. 50-60 min)

Gleiche Reihenfolge wie die Ringe im Deck. Pro Zeile: **Ampel** (GRÜN = passt · GELB = teilweise · ROT = fehlt), **Beleg** (Screenshot-Nr., geschwärzt), bei GELB/ROT eine **Massnahme mit Datum**. Format frei: Tabellen ausgefüllt als PDF/Foto oder eigenes Dokument mit denselben Punkten.

A1 · Ring 1 an dir: deine Konten (MFA-Inventar, ca. 25 min)

Deine 6 wichtigsten Konten, MINDESTENS: privates E-Mail (der Generalschlüssel: darüber läuft jedes «Passwort vergessen»), Google/Apple-ID, GitHub, Microsoft 365, E-Banking, 1 nach Wahl.

#	KONTO	MFA AN? ART (APP/SMS/PASKEY)	PASSWORT EINZIGARTIG + AUS DEM MANAGER?	RECOVERY-CODES GESICHERT (WO)?	AMPEL	MASSNAHME + BIS WANN
1	Privates E-Mail					
2	Google / Apple-ID					
3	GitHub					
4	Microsoft 365					
5	E-Banking					
6	(eigene Wahl)					

Hinweise: SMS-MFA zählt als GELB (besser als nichts, aber abfangbar; App oder Passkey = GRÜN). «Passwort im Browser gespeichert» ist kein Passwort-Manager (GELB).

A2 · Ring 2 an deinem Gerät (ca. 20 min)

#	PRÜFPUNKT	WO NACHSCHAUEN (MAC / WINDOWS)	AMPEL	BELEG	MASSNAHME + BIS WANN
1	Festplatte verschlüsselt (FileVault / BitLocker)	Systemeinstellungen → Datenschutz und Sicherheit → FileVault · Einstellungen → Datenschutz → BitLocker			
2	Bildschirm Sperre automatisch, Passwort sofort nötig	Sperrbildschirm-Einstellungen (max. 5 min)			
3	Betriebssystem aktuell, automatische Updates AN	Softwareupdate / Windows Update			
4	Malware-Schutz aktiv (Mac: XProtect/Gatekeeper ab Werk · Windows: Defender AN?)	Windows: Sicherheit auf einen Blick			
5	Separater Admin: arbeitest du im Alltag als Administrator?	Benutzerkonten anschauen (Least Privilege am eigenen Gerät)			
6	«Wo ist?» / «Mein Gerät suchen» aktiviert (Remote-Sperre)	Apple-ID / Microsoft-Konto			

A3 · Ring-4-Gedanke: deine Zugriffs-Landkarte (ca. 10 min)

Beantworte in 5-8 Sätzen: **Wer könnte heute auf was zugreifen, wenn dein Laptop JETZT gestohlen würde?** Geh die Kette durch: Kommt der Dieb rein (Sperre? Verschlüsselung)? Was ist im Browser eingeloggt? Wohin führt dein E-Mail-Konto? Was davon betrifft nicht dich, sondern Automatisierbar-Kunden? Schliess mit einem Satz, den du am 5.8. so sagen könntest: «Wer bei uns hat Zugriff auf Kundendaten, und warum genau die?»

Aufgabe B · 5 Begriffe an DEINEM Beispiel (ca. 20-25 min)

Erkläre die folgenden 5 Begriffe in je 2-3 Sätzen, **zwingend am Beispiel aus deinem eigenen Audit** (nicht abstrakt, nicht aus dem Primer kopiert). So klingst du am 5.8. nach Erfahrung statt nach Auswendiglernen.

1. **MFA**: am Beispiel eines deiner Konten aus A1 (welche Art, welches Ketten-Glied sie bricht).
2. **Geräteverschlüsselung (at rest)**: am Beispiel deines Laptops aus A2 (was passiert beim Diebstahl mit/ohne).
3. **Least Privilege**: am Beispiel deines Admin-Kontos (A2, Punkt 5) oder eines Kontos, das mehr darf als nötig.
4. **RPO**: Wenn dein Laptop heute stirbt: was wäre weg, von wann ist die letzte Kopie? Das IST dein persönliches RPO.
5. **Die Phishing-Kette**: Wie käme ein Angreifer über DEIN E-Mail-Konto (A1, Zeile 1) an ein zweites Konto, und welches deiner Häkchen bricht die Kette an welchem Glied?

Extra-Aufgabe (freiwillig, +30 min) · Angriffs-Drehbuch auf Automatisierbar

Wechsle die Seite: Du bist der Angreifer und willst an Automatisierbar-Kundendaten. Schreibe ein Drehbuch in 5 Szenen, wie in der Session: **(1)** Wen von uns vier greifst du an, und warum ausgerechnet ihn? **(2)** Mit welcher Mail/Nachricht (Vorwand, Absender, Zeitpunkt, gerne ausformuliert)? **(3)** Was ist deine Beute? **(4)** An welchem Glied scheiterst du an unseren heutigen Massnahmen, und wo kämst du durch? **(5)** Was müssten wir ändern, damit dein Drehbuch sicher scheitert? Nutze dein Insider-Wissen: genau das macht echte Angriffe gefährlich und diese Übung wertvoll. Die beste Einreichung wird Anschauungsmaterial für die 5.8.-Vorbereitung.

Abgabe

1. Alles in EINE Datei packen, wenn möglich (PDF am einfachsten: Fotos der ausgefüllten Tabellen + Text). Mehrere Dateien gehen auch (max. 15 MB pro Datei).
2. Hub öffnen: cockpit.automatisierbar.ch/vrv → Lernen → Karte Modul 2 → **Abgaben ansehen** → Name wählen, Datei hochladen, kurzer Kommentar.
3. **Frist: Mittwoch, 15. Juli 2026, 18:00**. Die Abgaben sind für alle vier sichtbar; wir besprechen die Ampeln (nicht die Details) kurz in der nächsten Session.
4. ROTE Punkte müssen nicht vor der Abgabe gefixt sein. Ehrliche Rots mit Massnahme sind der Sinn der Übung; ein geschöntes Audit ist wertlos.